

Simtec Consult - Supplier and Cloud Service Security Policy

Version: 1.1

Status: Approved

Owner: Director

Applies to: suppliers, SaaS tools, cloud platforms, contractors, customer platforms

Related to: Cyber Essentials, UK GDPR

Last reviewed: 2026-08-03

Next review due: 2026-11-03

Purpose

Simtec relies on cloud services, SaaS tools, hosting providers, customer platforms, and some external parties. This policy sets approval, review, and access expectations.

Policy

New suppliers or cloud services must be approved by a Director before use for Simtec or customer data.

Cloud services used to host primary customer application data must support storage in a UK or EEA region unless a different location is agreed with the customer in writing. Other supplier processing locations and international transfers must be identified and addressed where applicable.

Approval should consider business purpose, data processed or stored, whether personal data is involved, authentication and MFA support, access control and administrator model, security update responsibilities, backup and export options, data location or international transfer risk, contract or data processing terms, exit plan, and deletion approach.

Simtec must maintain a cloud services register showing service name, purpose, owner or administrator, users and administrators, data processed, MFA status, supplier security evidence where available, legal entity or certification scope, review date, and exit notes where relevant.

All cloud services that store or process Simtec data are in scope for Cyber Essentials and must not be excluded.

Approved suppliers and cloud services should support named accounts, MFA for users and administrators where available, least-privilege access, secure password or passwordless authentication, encryption in transit, encryption at rest where available, security update management, prompt user removal, audit logs where appropriate, and data export or recovery where practical.

Supplier or contractor access must be limited to the approved purpose, time-bound where practical, granted through named accounts, protected by MFA where available, removed promptly when work ends, and reviewed when suppliers, projects, or responsibilities change.

Shared credentials must be avoided. Where unavoidable, they must be stored in the approved password manager and rotated when access changes.

Where a supplier processes personal data for Simtec, appropriate contract terms or data processing terms must be in place. Where Simtec uses a customer-provided platform, staff must follow customer access and data handling instructions unless they conflict with legal or security obligations.

Supplier security incidents that may affect Simtec or customer data must be handled under `policies/incident-response-and-personal-data-breach-plan.md`.

Review

Material suppliers and cloud services are reviewed at least annually and when suppliers, services, access, contracts, or data processing change.

Review History

Date	Reviewer	Description	Next review due
2026-08-03	Policy Manager	Added supplier selection requirements supporting the approved UK or EEA default location for primary customer application data.	2026-11-03
2026-06-03	Policy Manager	Created current policy document aligned to Simtec requirements and relevant Cyber Essentials answers.	2026-09-03